

The background is a dark blue-tinted image of an industrial factory floor. In the foreground, there are metal workbenches and equipment. In the background, there are various industrial machines and structures. Overlaid on the image are several circular data elements: a gauge showing '+80%', another showing '+79%', and a larger one showing '94%' with '01 - 1000' written below it. The text 'UnISENAI' is prominently displayed in the center.

UnISENAI

O FUTURO COMEÇA
POR VOCÊ!

Análise e Desenvolvimento de Sistemas

Fundamentos de Segurança da Informação

Normas, leis e políticas de segurança

- ISO 27001, LGPD, Marco Civil

UniSENAI



Sistema de Gestão da Segurança da Informação (SGSI)

O SGSI tem o objetivo de garantir a segurança das informações da Organização, por exemplo, assegurando os pilares da segurança da informação através da utilização de uma abordagem de gestão de riscos, além do mais, fornece a confiança às partes interessadas de que os riscos da Organização são gerenciados de forma adequada.

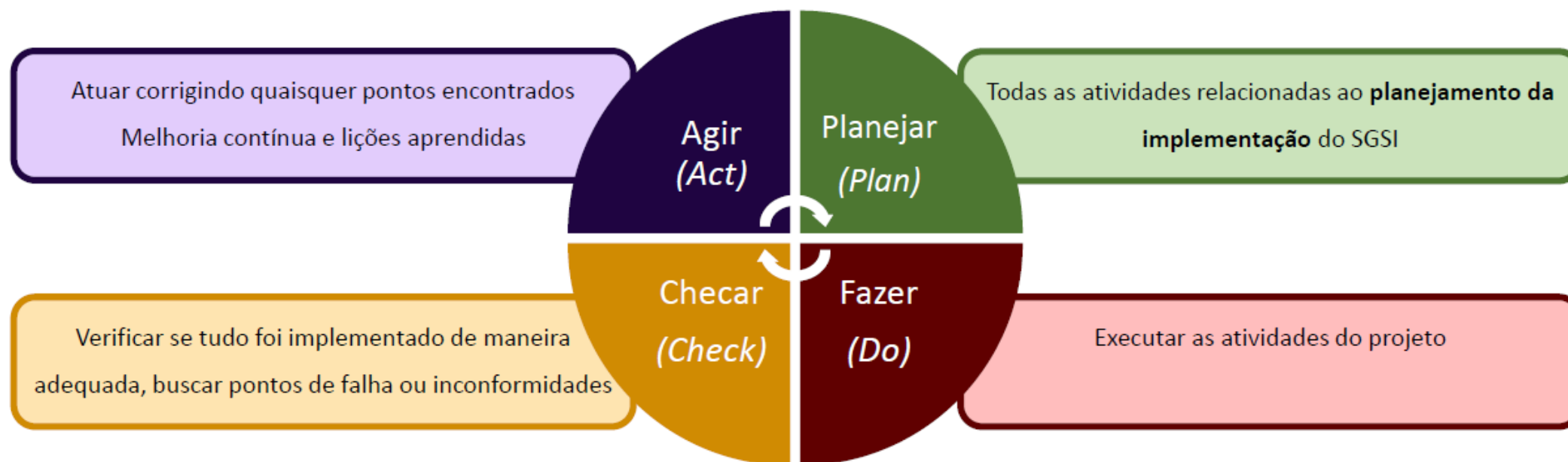


A ISO fornece normas que auxiliam e especificam os requisitos para estabelecer, implementar, manter e melhorar um SGSI dentro do contexto da organização.

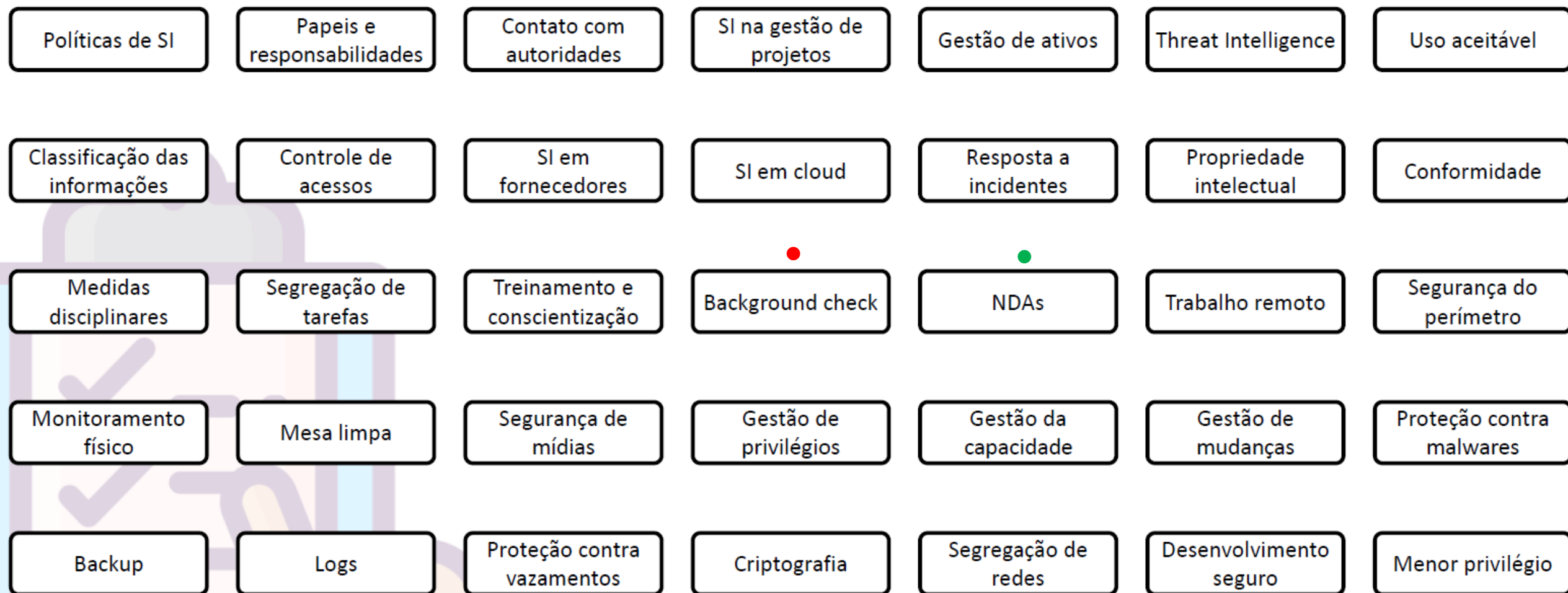
As principais são:

- ISO 27001 - Técnicas de Segurança - Sistemas de gestão da segurança da informação - Requisitos
- ISO 27002 - Controles de segurança da informação

Ciclo PDCA – implementação do Sistema



Implementação de um SGSI – Exemplos/Prática



● Background check - (checagem de antecedentes) . Trata-se de um processo para a verificação de antecedentes de um potencial parceiro comercial, por meio de consulta a fontes públicas e/ou privadas de dados.

● Non Disclosure Agreement (acordo de não-divulgação), é um documento de acordo de sigilo de informações. Como o nome indica, trata-se de um documento usado para proteger informações que exigem confidencialidade.

Leis e Padrões



Payment Card Industry Data Security Standard (PCI DSS): É um padrão de segurança de informações usado para lidar com cartões de crédito, seu uso é obrigatório pelas empresas que lidam com atividades relacionadas a utilização e processamento de cartões de crédito. O PCI fornece um conjunto de requisitos que tem como premissa assegurar a proteção de informações confidenciais e garantir a segurança de dados sensíveis em transações financeiras.



International Organization for Standardization (ISO): A ISO é conhecida mundialmente, ela desenvolve e publica padrões que são utilizados por diversas indústrias e setores no mundo. A família ISO 27000 nos traz as normas relacionadas ao tema de segurança da informação, das quais, as principais são as ISO's 27001 e 27002.



Health Insurance Portability and Accountability Act (HIPAA): É um conjunto de normas que organizações de saúde norte-americanas devem cumprir para proteger as informações.



Sarbanes Oxley Act (SOX): Assegurar a transparência na gestão das empresas quando aos aspectos financeiros, o objetivo é exigir das companhias maior governança nas informações divulgadas e, conseqüentemente, dar maior segurança aos stakeholders sobre seus investimentos.



General Data Protection Regulation (GDPR): O Regulamento Geral sobre a Proteção de Dados, trata sobre a privacidade e proteção de dados pessoais, aplicável a todos os indivíduos na União Europeia e Espaço Econômico Europeu.



Lei Geral de Proteção de Dados (LGPD): Regula as atividades de tratamento de dados pessoais

Governança na Segurança da Informação

A Governança de Segurança da Informação **visa gerenciar as atividades relacionadas a SI na organização através do alinhamento dos objetivos e estratégias da SI com os objetivos e estratégias do negócio**, além de estar em conformidade com os aspectos legais, regulatórios e contratuais aos quais a organização esteja sujeita, toda essa gestão é implementada por meio de uma **abordagem baseada na gestão dos riscos da organização**.



Objetivos da Governança de Segurança da Informação:

- Alinhamento dos objetivos e estratégias da SI com os do negócio;
- Agregar valor para as partes interessadas (Stakeholders);
- Assegurar que os riscos de SI são bem gerenciados na Organização



Resultados esperados

- Visibilidade da Organização quanto a SI
- Abordagem ágil para tomada de decisões
- Eficiência e eficácia quanto aos investimentos necessários
- Conformidade com os requisitos



ISO 27014 - Governança de segurança da informação



Governança da Organização



Governança de TI

Governança de SI

Princípios de Governança de SI – ISO 27014

Princípio 1 - Estabelecer a segurança da informação em toda a organização

A Segurança da Informação deve ser **compreendida e integrada ante as pessoas, processos e tecnologias da Organização, para tanto, é preciso definir os papéis e responsabilidades das partes envolvidas**, sejam internos ou externos a fim de que as atividades físicas ou lógicas sejam adequadamente coordenadas.

Princípio 2 - Adotar uma abordagem baseada em riscos

As tomadas de **decisões quanto a Segurança da Informação devem ser baseadas nos riscos da Organização, assim como, a definição do apetite a risco da organização deve ser definida para auxiliar nas decisões**. A Organização deve disponibilizar quaisquer recursos que sejam necessários relacionadas a Gestão de Riscos dado a sua importância estratégica.

Princípio 3 - Estabelecer a direção de decisões de investimento

Deve ser estabelecido as **estratégias de investimentos da Segurança da Informação de acordo com os resultados e objetivos da Organização. Os requisitos e necessidades presentes e futuras da Organização devem ser consideradas na estratégia de investimento**, além do mais, a Segurança da Informação deve estar incluída nos processos da Organização de gastos/investimentos.

Princípios de Governança de SI – ISO 27014

Princípio 4 - Assegurar conformidade com os requisitos internos e externos

As **políticas e procedimentos da Segurança da Informação devem estar de acordo com os requisitos internos, legais, regulatórios ou contratuais aos quais a Organização esteja sujeita**. Também é necessário que auditorias sejam realizadas, a fim de validar o estado de conformidade da Segurança da Informação.

Princípio 5 - Promover um ambiente positivo de segurança

A **cultura da Segurança da Informação deve ser implementada na Organização**, campanhas e atividades relacionadas a treinamentos e conscientização devem ser realizadas e suportadas pela Alta Direção da Organização, a Alta Direção deverá exigir, promover e apoiar a coordenação de tais atividades.

Princípio 6 - Analisar o desempenho em relação aos resultados de negócios

A abordagem utilizada pela Segurança da Informação devem ser adequadas ante os objetivos e estratégias da Organização, e assim, ter um nível coerente de eficiência da Segurança da Informação. **A Alta Direção da Organização deve analisar criticamente o desempenho da Segurança da Informação, avaliando e validando a relação entre a Segurança da Informação e os possíveis impactos associados ao seu desempenho.**

Papéis/Funções/Estruturas em SI

Chief Information Security Officer (CISO):

- Responsável pela liderança e estratégia de segurança da informação da organização.
- Define e implementa políticas, procedimentos e controles de segurança.
- Supervisiona equipes de segurança da informação e garante conformidade com regulamentações e padrões de segurança.

Analista de Segurança da Informação:

- Monitora a infraestrutura de TI em busca de possíveis ameaças e vulnerabilidades.
- Realiza análises de risco e investigações de incidentes de segurança.
- Implementa e mantém soluções de segurança, como firewalls, antivírus e sistemas de detecção de intrusões.

Realiza testes para identificar e corrigir vulnerabilidades.

Engenheiro de Segurança da Informação:

- Projetar, implementar e manter infraestruturas de segurança de TI.
- Desenvolve e implementa soluções de segurança.
- Realiza testes para identificar e corrigir vulnerabilidades.

Analista de Compliance e Governança de Segurança:

- Garante que a organização esteja em conformidade com regulamentações de segurança, como LGPD.
- Desenvolve e mantém políticas e procedimentos de segurança.
- Coordena auditorias de segurança e responde a requisitos de conformidade.

Analista de Resposta a Incidentes de Segurança:

- Coordena a resposta a incidentes de segurança, investigação, contenção e mitigação.
- Documenta e relata incidentes de segurança, mantendo registros para análise pós-incidente.
- Desenvolve planos de resposta a incidentes e conduz exercícios de simulação.

Administrador de Redes e Sistemas:

- Configura e mantém servidores, ativos de rede e sistemas operacionais de forma segura.
- Realiza backups e recuperação de dados em caso de incidentes de segurança.
- Implementa e gerencia soluções de segurança de rede, como firewalls e VPNs.

E os Terceirizados ?

Quanto a relação dos terceiros para com a Segurança da informação, podemos considerar alguns pontos, como por exemplo:

Algumas empresas terceirizadas não são transparentes quanto aos riscos de segurança da informação que eles “trazem” para a organização, uma avaliação de riscos sobre os terceiros deve ser considerada.

Os requisitos de Segurança da Informação devem ser expressados de maneira explícita por meio das cláusulas contratuais por exemplo.

Gestão dos recursos, Ambiente seguro, Conformidades e requisitos, Transparência entre as partes, Níveis de garantia coerentes, são alguns dos objetivos que precisam ser “colocados na mesa” , quando o momento de negociação.

- Os parceiros devem **compreender as estratégias e requisitos da Organização**;
- Implementação e análise dos **requisitos de Segurança da Informação nos contratos**;
- **Realização de due care e due diligence** entre as partes, a fim de verificar o estado de conformidade da Segurança da Informação na Empresa;
- Utilização de **boas práticas e padrões de mercado/indústria**;
- **Definição de SLAs** quanto aos serviços e desempenho da Segurança da Informação;
- **Monitoramento e gestão de vulnerabilidades**.

Due Care (Devido Cuidado) - É o nível de atenção e cuidado que uma pessoa ou organização razoável adotaria para evitar danos a si mesma ou a terceiros em uma situação específica.

Foco: Medidas internas e contínuas para manter a segurança e a proteção de ativos.

Due Diligence (Devida Diligência) - É um processo de investigação e pesquisa minuciosa para coletar e analisar informações antes de tomar uma decisão ou assumir um compromisso.

Foco: Análise externa e aprofundada de riscos e detalhes antes de um evento.

E a Organização ?

Quanto a **relação da organização para com a Segurança da informação**, podemos considerar alguns pontos, como por exemplo:

A informação possui um peso enorme para os Organizações, ela é um dos principais ativos da atualidade.

As organizações precisam cada vez mais estarem aderentes as leis, normas e regulamentos, como por exemplo, a LGPD, que trata da privacidade dos dados pessoais, uma empresa que lide com dados pessoais sensíveis e não esteja em conformidade com a LGPD pode sofrer duras penalidades, além da multa, a reputação da empresa ficaria manchada, e assim, muitas empresas não teriam interesse em ser associadas a essa empresa.

Objetivos:

- Estratégias
- Agregar valor
- Lucro
- Vantagem competitiva
- Conformidade regulatória
- Segurança dos ativos de informação

Partes Interessadas

- Presidente
- Diretoria
- Gerentes
- Supervisores
- Coordenadores
- Áreas do Negócio - Donos dos processos

- ✓ As Organizações são **obrigadas a cumprirem com as melhores práticas** quanto a privacidade de dados e propriedade intelectual;
- ✓ **A informação virou um dos recursos mais valiosos da atualidade**, logo, ela precisa ser protegida por um sistema de segurança que seja funcional e adequado de acordo com a criticidade da informação;
- ✓ Partes externas (parceiros, clientes e fornecedores por exemplo) **exigem transparência e conformidade da organização**;
- ✓ Na era que vivemos, **qualquer evento que ocorra pode escalar e rapidamente causar um grande impacto** à imagem da Organização

E os Clientes ?

Quanto a **relação dos clientes para com a Segurança da informação**, podemos considerar alguns pontos, como por exemplo:

Como cliente, queremos sempre **a melhor opção disponível no mercado**, não apenas quanto ao preço mas **como a reputação e disponibilidade da empresa por exemplo**, queremos saber se a empresa segue **as melhores práticas e nossos dados pessoais estão seguros**, assim como, queremos que o site da empresa esteja sempre disponível quando quisermos fazer uma nova compra.

Objetivos:

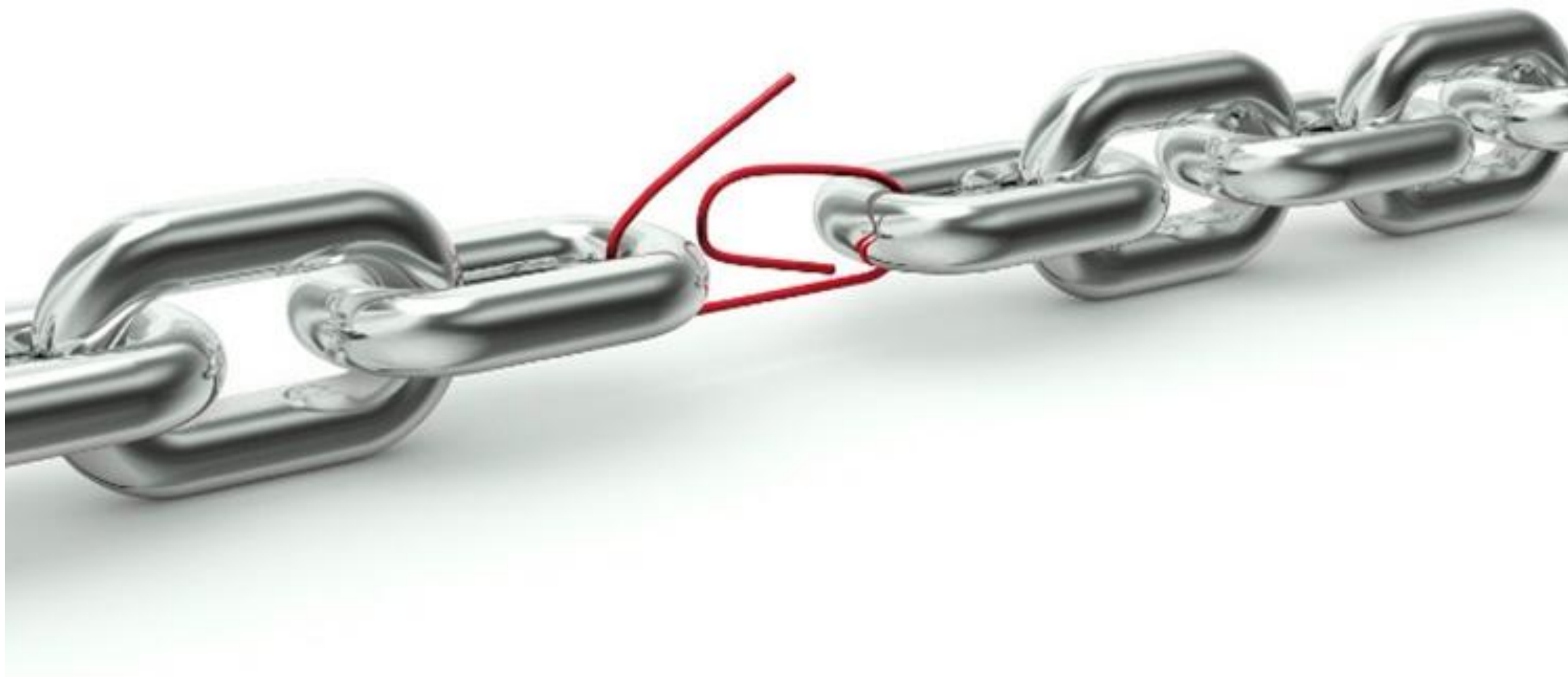
- Consumo dos serviços da Organização
- Custo benefício
- Privacidade
- Visibilidade da Organização
- Confiança nos serviços prestados

Partes Interessadas:

Clientes (pessoas físicas ou jurídicas)
sejam internas ou externas

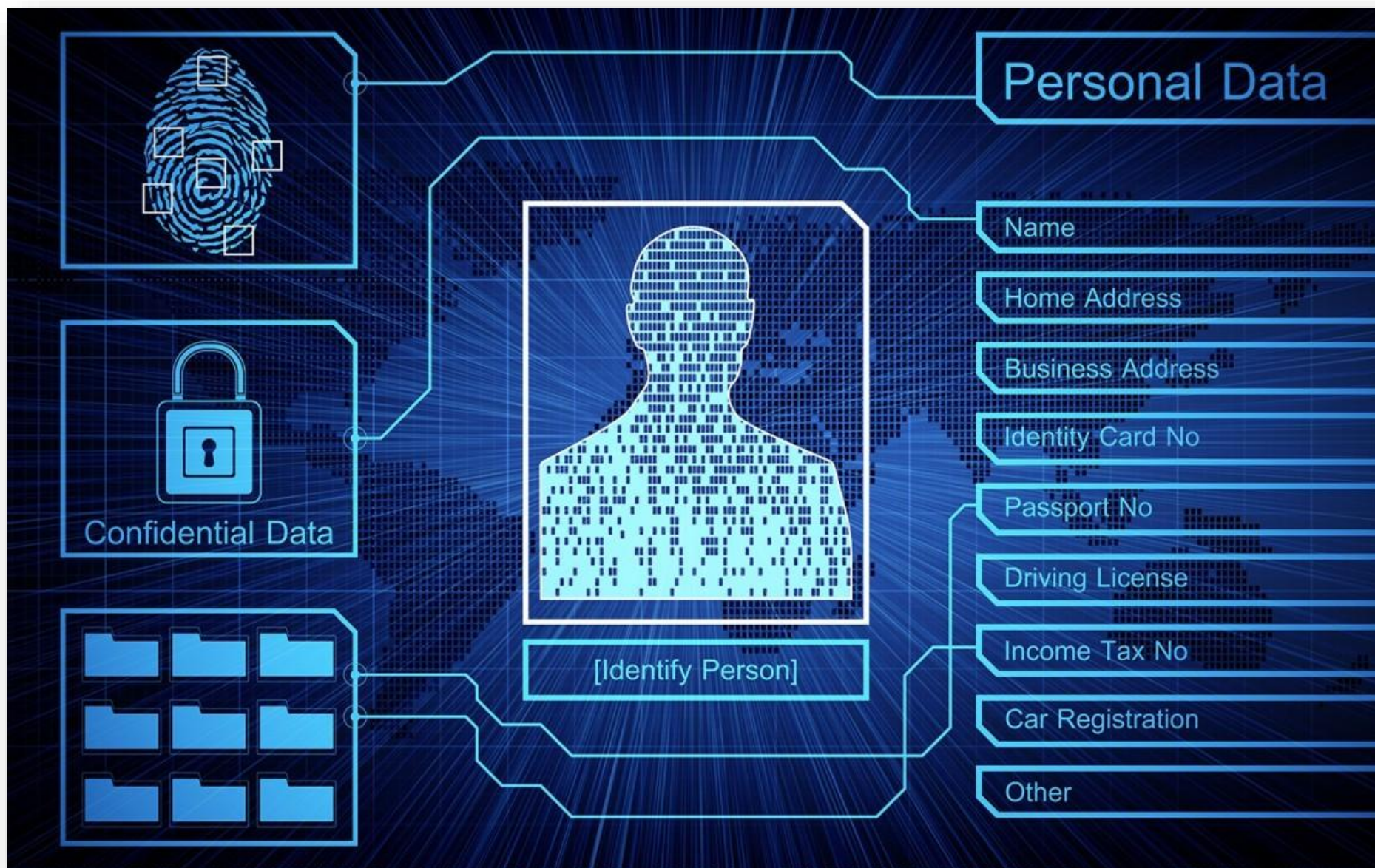
- ✓ A relação da Organização com seus clientes **requerem a implementação da adequada governança e conformidade** para que haja uma confiança que suporte essas relações;
- ✓ Como cliente, muitas vezes essas **partes não sabem quais provas devem exigir para se decidirem sobre a correta gestão dos riscos de segurança da informação** da Organização;
- ✓ A Segurança da Informação é **muitas vezes vista pelos clientes finais como um recurso superficial**, por exemplo, se o site tiver HTTPS a Empresa é confiável.
- ✓ Os clientes finais **normalmente não recebem treinamentos de segurança da informação** – poucas empresas realizam campanhas de conscientização para seus clientes;

Qual é o elo mais fraco em Segurança da Informação ?





Por que a privacidade de dados é importante?



Privacidade de Dados

Os fundamentos da privacidade de dados incluem **confidencialidade** de dados, **segurança** de dados, **limitações** de quais dados são coletados e usados, **transparência** em como os dados são usados e a conformidade com as leis de privacidade de dados apropriadas.

LGPD – Legislação:

LEI Nº 13.709, DE 14 DE AGOSTO DE 2018.

Lei Geral de Proteção de Dados Pessoais (LGPD).



LEI Nº 13.853, DE 8 DE JULHO DE 2019

Conversão da Medida Provisória nº 869, de 2018

Mensagem de veto

Altera a Lei nº 13.709, de 14 de agosto de 2018, para dispor sobre a proteção de dados pessoais e para criar a Autoridade Nacional de Proteção de Dados; e dá outras providências.



Obrigatoriedade LGPD

Lembre-se de que a Lei Geral de Proteção de Dados ou LGPD existe para nos proteger de empresas que não tratam os nossos dados pessoais e sensíveis com a responsabilidade e atenção devidas.

Durante muitos anos, nossas informações foram compartilhadas de forma inadequada e sem autorização.

Globalmente, esse tipo de iniciativa não é mais aceita e acarreta muitas pesadas, perda de confiabilidade da empresa que faz o compartilhamento indevido, ações judiciais por uso indevido das informações, e muito mais.

Agora, temos uma lei que observa nossos direitos de titular dos dados e atribui sanções aos que insistem em tentar burlar a lei.

Atenção

Por se tratar de uma lei, a adequação das empresas é obrigatória.



10 – Princípios LGPD

- 01 Finalidade especificada e informada explicitamente ao titular
- 02 Adequação à finalidade previamente acordada e divulgada
- 03 Necessidade do tratamento, limitado ao uso de dados essenciais para alcançar a finalidade inicial
- 04 Acesso livre, fácil e gratuito das pessoas à forma como seus dados são tratados
- 05 Qualidade dos dados, deixando-os exatos e atualizados, segundo a real necessidade no tratamento
- 06 Transparência, ao titular, com informações claras e acessíveis sobre o tratamento e seus responsáveis
- 07 Segurança para coibir situações acidentais ou ilícitas, como invasão, destruição, perda e difusão
- 08 Prevenção contra danos ao titular e demais envolvidos
- 09 Não discriminação, ou seja, não permitir atos ilícitos ou abusivos
- 10 Responsabilização do agente, obrigado a demonstrar a eficácia das medidas



1



Finalidade

Apenas coletar dados pessoais para fins legítimos, informando com clareza o usuário a finalidade da coleta.

Finalidade: a realização do tratamento deve ocorrer para propósitos legítimos, específicos, explícitos e informados ao titular, sem possibilidade de tratamento posterior de forma incompatível com essas finalidades.

2



Adequação

Disponibilizar todas as informações sobre a coleta e uso de dados para o usuário, de forma honesta.

Adequação: a compatibilidade do tratamento deve ocorrer conforme as finalidades informadas ao titular, de acordo com o contexto do tratamento.

3



Necessidade

Manter e utilizar apenas os dados essenciais, apagando-os quando deixarem de ser relevantes.

Necessidade: o tratamento deve se limitar à realização de suas finalidades, com abrangência dos dados pertinentes, proporcionais e não excessivos em relação às finalidades do tratamento de dados.

4



Livre acesso

Ser capaz de apresentar ao usuário os dados e a forma como são processados ao ser requisitado.

Livre acesso: é a garantia dada aos titulares de consulta livre, de forma facilitada e gratuita, à forma e à duração do tratamento, bem como à integralidade de seus dados pessoais.

5



Precisão

Manter os dados precisos a todo o momento, deletando ou atualizando dados errados ou imprecisos.

Qualidade dos dados ou precisão: é a garantia dada aos titulares de exatidão, clareza, relevância e atualização dos dados, de acordo com a necessidade e para o cumprimento da finalidade de seu tratamento.

7



Segurança

Tomar medidas técnicas e administrativas para proteger os dados de danos, furtos ou perdas.

Segurança: trata-se da utilização de medidas técnicas e administrativas qualificadas para proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração, comunicação ou difusão.

6



Transparência

O usuário deve ser informado, de maneira clara e acessível, sobre os riscos e direitos sobre seus dados.

Transparência: é a garantia dada aos titulares de que terão informações claras, precisas e facilmente acessíveis sobre a realização do tratamento e os respectivos agentes de tratamento, observados os segredos comercial e industrial.

8



Prevenção

Tomar medidas preventivas para a proteção dos dados, evitando danos aos titulares.

Prevenção: compreende a adoção de medidas para prevenir a ocorrência de danos por causa do tratamento de dados pessoais.

9



Não discriminação

Não utilizar os dados para nenhum fim discriminatório, ilícito ou abusivo, atendendo aos requisitos de lei.

Não discriminação: sustenta que o tratamento dos dados não pode ser realizado para fins discriminatórios, ilícitos ou abusivos.

10



Responsabilidade

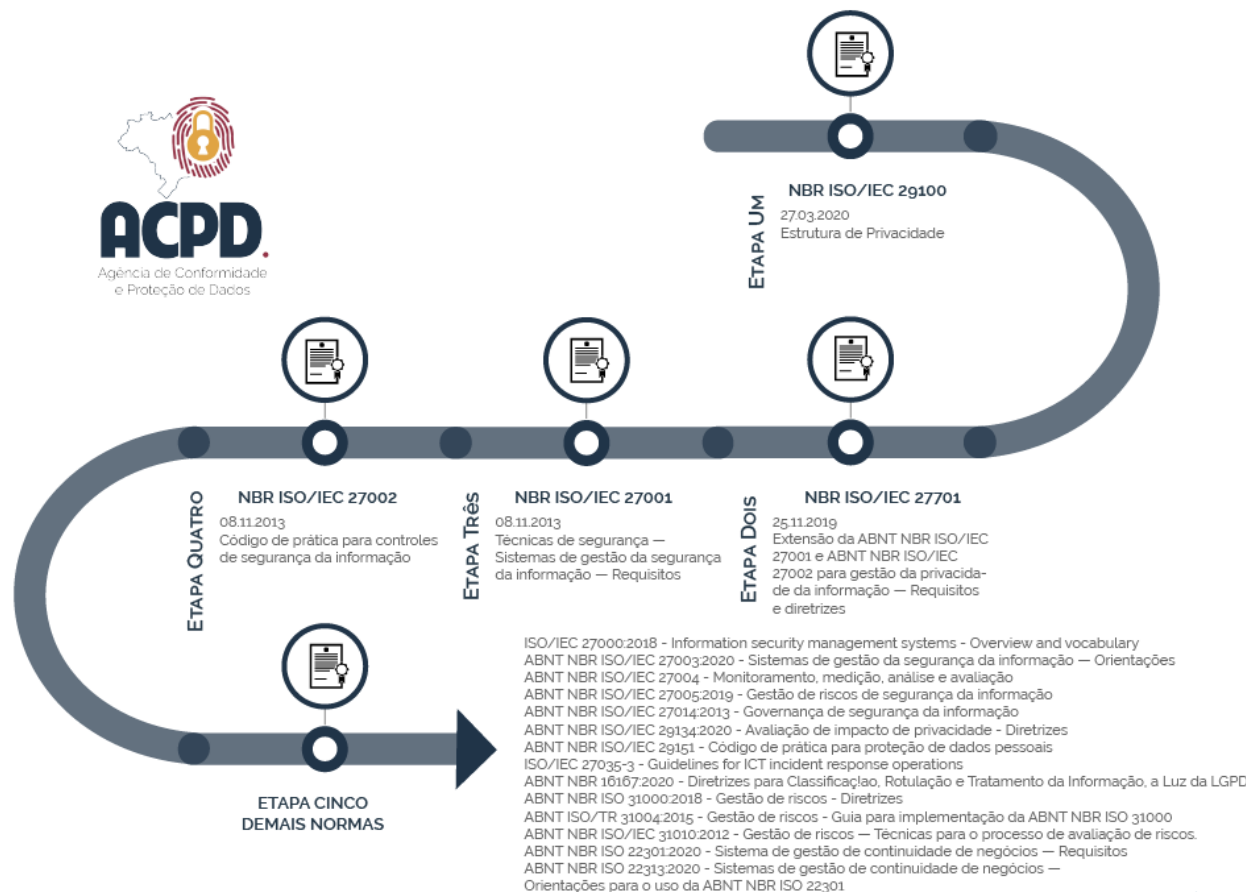
Adotar esses princípios e ter condições de provar sua adoção em todos os procedimentos da empresa.

Responsabilização e prestação de contas: demonstração, pelo Controlador ou pelo Operador, de todas as medidas eficazes e capazes de comprovar o cumprimento da lei e a eficácia das medidas aplicadas.



NORMAS TÉCNICAS PARA LGPD

ROADMAP | TRILHA DA CAPACITAÇÃO



WWW.ACPDBRASIL.COM

Privacidade

A privacidade pode ser entendida como a capacidade do titular determinar como, quando e quais informações sobre ele serão compartilhadas com outras partes, ou seja, significa que a informação será utilizada apenas pelos métodos conhecidos pela qual o titular as forneceu.

Titular

Pessoa natural a quem se referem os dados pessoais que são objeto de tratamento

Dado pessoal

São informações relacionadas a uma pessoa natural identificada ou identificável

Dado pessoal sensível

São dados pessoais sobre origem racial ou étnica, religião, opinião política, filiação a sindicato ou a organização de caráter religioso, filosófico ou político, dado referente à saúde ou à vida sexual, dado genético ou biométrico, quando vinculado a uma pessoa natural.

Operador

Pessoa natural ou jurídica, de direito público ou privado, que realiza o tratamento de dados pessoais em nome do controlador

Banco de Dados

Conjunto estruturado de dados pessoais, em um ou em vários locais, em suporte eletrônico ou físico.

Tratamento de Dados

Toda operação realizada com dados pessoais, como as que se referem a coleta, produção, recepção, classificação, utilização, acesso, reprodução, transmissão, distribuição, processamento, arquivamento, armazenamento, eliminação, avaliação ou controle da informação, modificação, comunicação, transferência, difusão ou extração.

Dado anonimizado

Dados relativos ao titular que não possam ser identificados, considerando a utilização de meios técnicos razoáveis e disponíveis em seu tratamento.

Eliminação

Exclusão de dado ou de conjunto de dados armazenados em banco de dados, independentemente do procedimento empregado

Controlador

pessoa natural ou jurídica, de direito público ou privado, a quem competem as decisões referentes ao tratamento de dados pessoais.

DPO (*Data Protection Officer*)

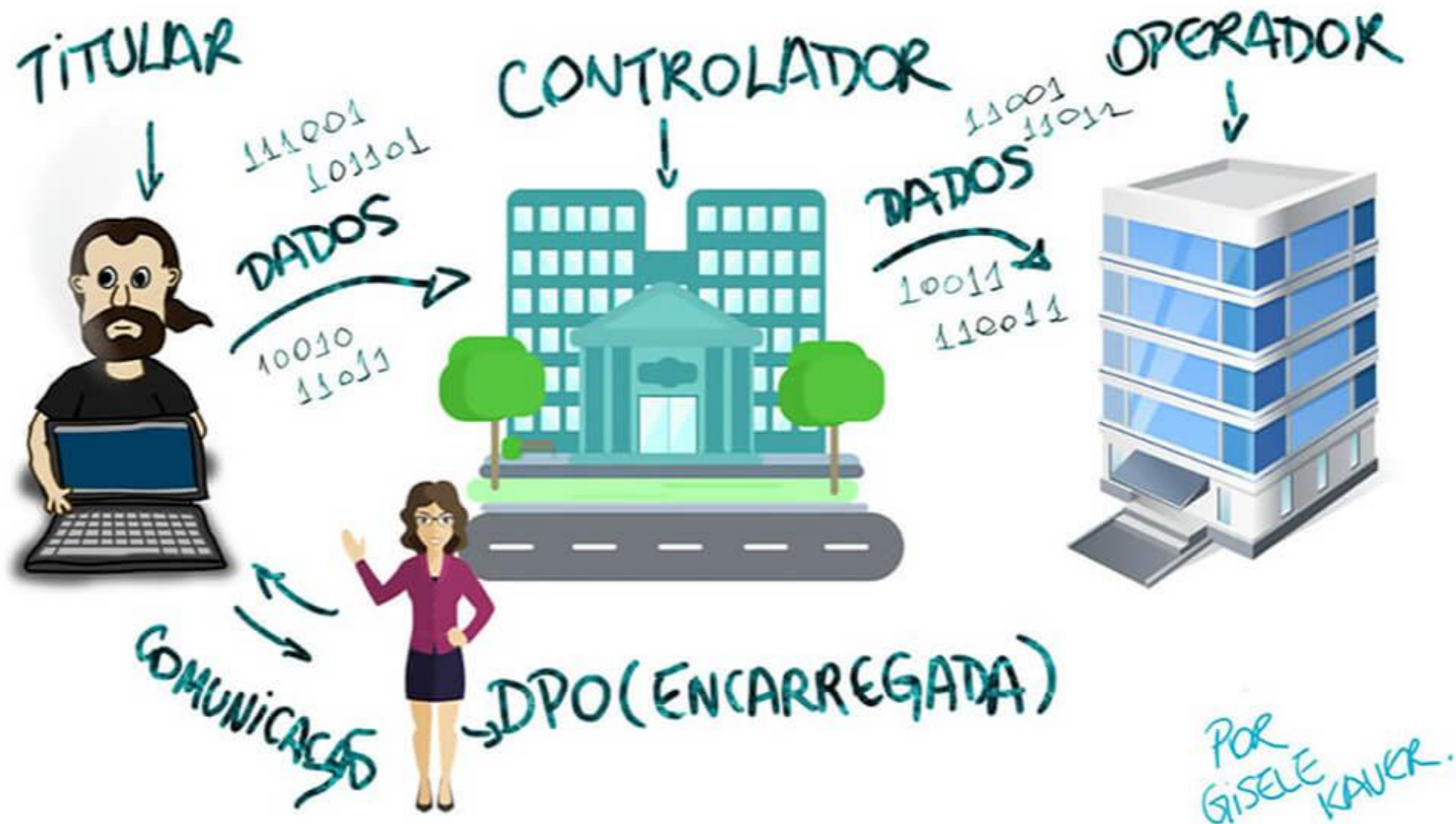
Manter o controle dos dados do titular nos contratos, nos projetos, nos novos desenvolvimentos e estar atento a mudanças nas leis e nas medidas provisórias e aditivos faz parte da gestão da Privacidade de Dados. O responsável por isso é o DPO (*Data Protection Officer*, ou algo como Encarregado de Proteção de Dados, em português), que será apoiado pelo Comitê de Privacidade de Dados.



Curiosidade

O DPO é o profissional responsável pelo cuidado das questões referentes à proteção dos dados da organização e de seus clientes.

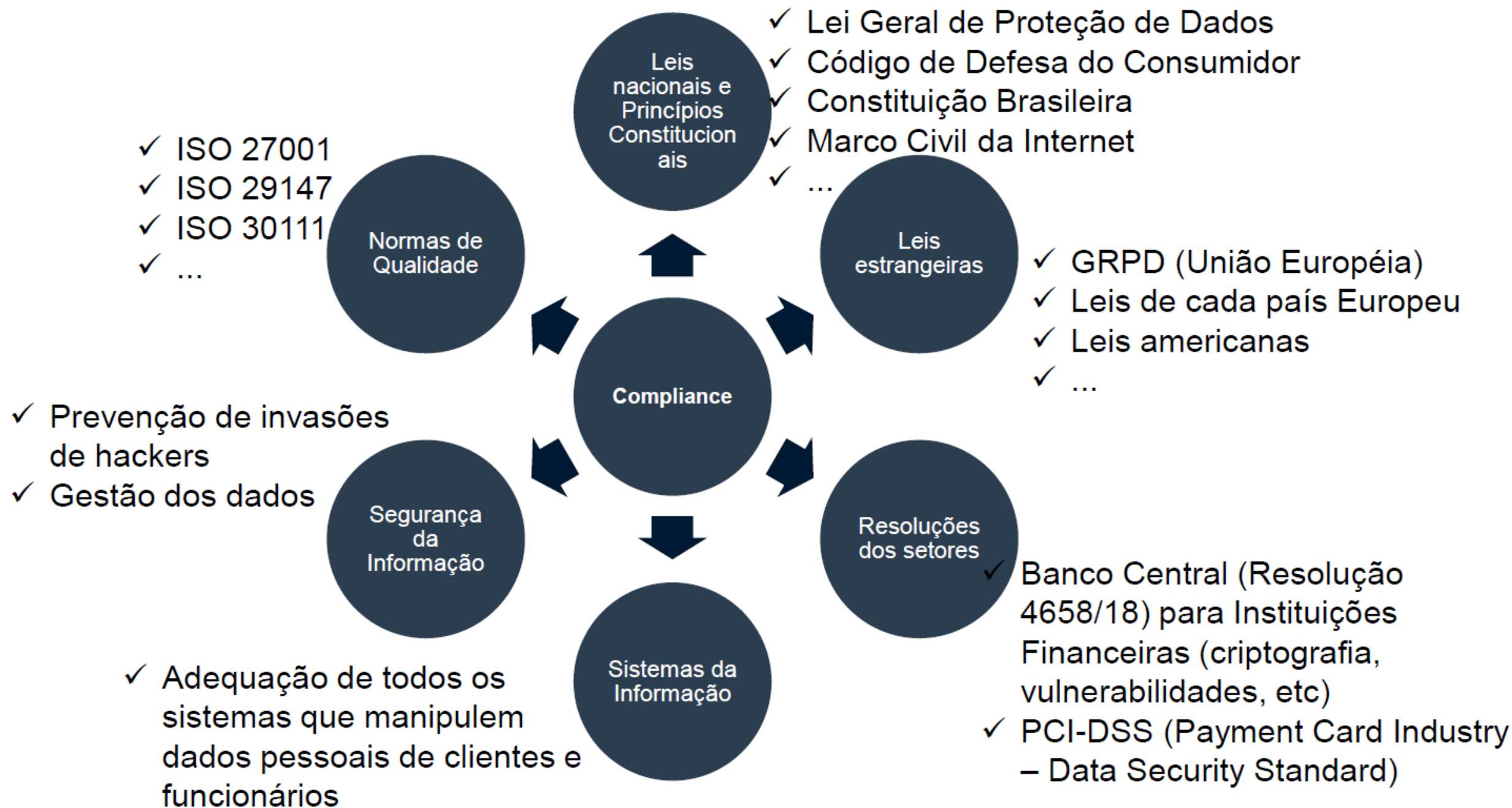




Compliance

- Compliance, termo de origem inglesa ("to comply" = cumprir), é um conjunto de políticas e processos que garantem que uma organização siga leis, regulamentos, normas e padrões éticos internos e externos, tanto no âmbito legal quanto no operacional.
- O objetivo principal é prevenir, detectar e corrigir irregularidades, minimizando riscos para a empresa, promovendo a integridade, a transparência e a sustentabilidade dos negócios





ISO 27000

Família 27000 – ISO/IEC 27000 series –

Organizações podem desenvolver e implementar **uma estrutura para gerenciara segurança de seus ativos de informação**

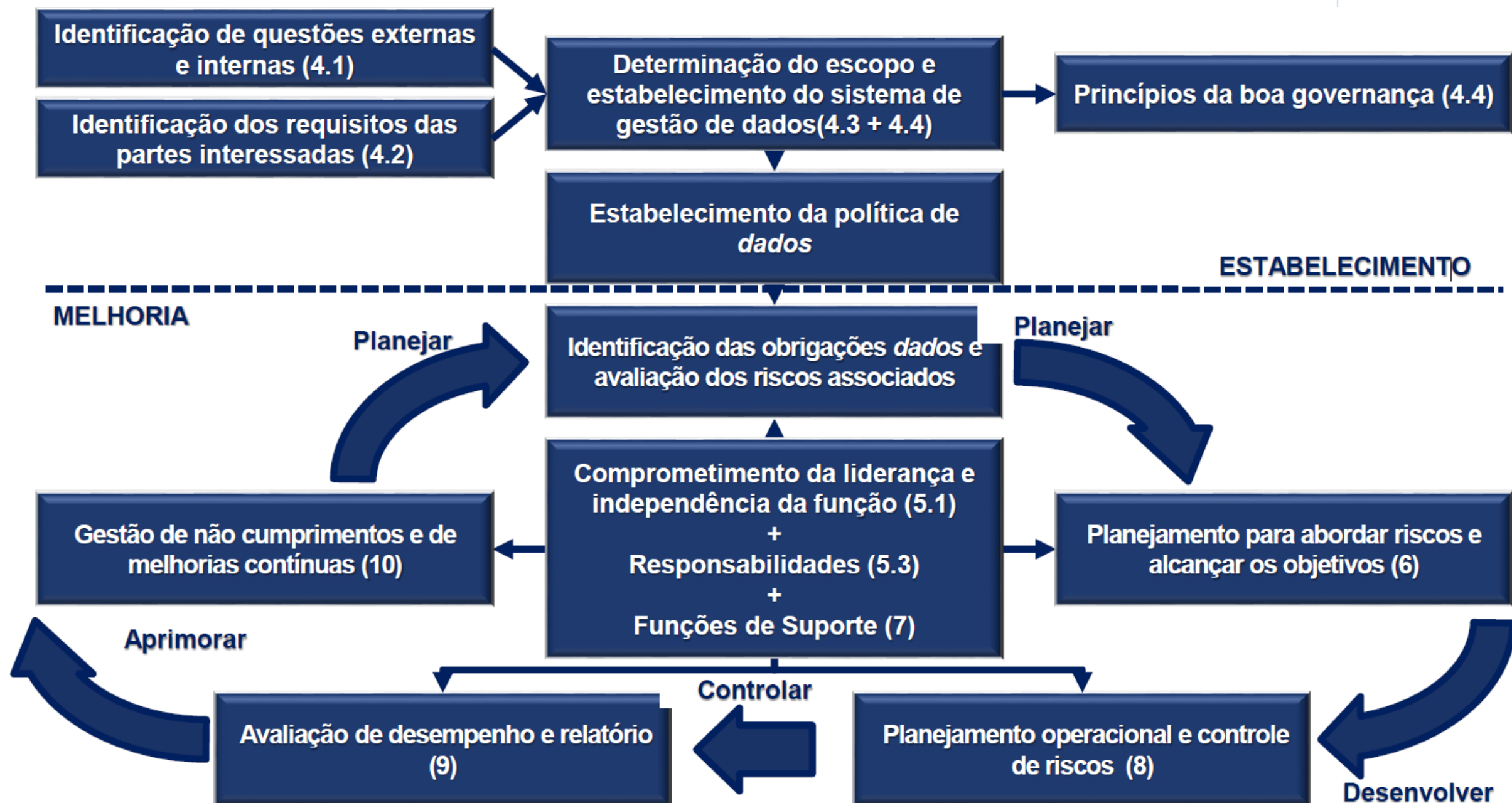
Se preparar para uma avaliação independente do seu SGSI (Sistema de Gestão de Segurança da Informação) aplicado à proteção de informações

Normas:

1. ISO/IEC 27002:2005 –Código de Prática para Gestão da Segurança da Informação
2. ISO/IEC 27005:2011 –Gestão de Riscos de Segurança da Informação
3. ISO/IEC 27007 :2012–Diretrizes para auditoria de SGSI
4. ISO/IEC 27014:2013 –Governança de segurança da informação 5/30



Implementação da Norma 27000



Quais são os requisitos ISO 27001 ?

Para obter a certificação ISO 27001, é necessário alinhar seu Sistema de Gerenciamento de Segurança da Informação com os requisitos da norma.

Esses requisitos visam ajudar as organizações a criar, manter e melhorar continuamente sua postura SGSI.

Existem **sete** requisitos da ISO 27001, listados nas cláusulas 4-10 da estrutura de conformidade, com a qual sua organização precisa se tornar compatível, são eles:

Requisito 1 - Contexto da organização (cláusula 4)

Antes de definir o seu escopo para a implementação do SGSI, é fundamental conhecer a sua empresa. Essa é uma parte crucial, pois informará às partes interessadas, incluindo gestores, **C-levels***, clientes, investidores, auditores e funcionários, quais áreas da sua empresa serão cobertas pelo seu planejamento. O auditor também usa esse escopo durante a Auditoria ISO 27001 para entender os riscos pelos quais você identificou e implementou medidas de segurança dentro da organização.

* Gestores C-level são executivos de altíssimo escalão em uma empresa, cujo nome começa com a letra "C" de "Chief" (chefe), e são responsáveis por definir e executar as estratégias de alto nível que moldam o presente e o futuro da organização. Eles lideram departamentos específicos, como finanças (CFO) ou tecnologia (CTO), e têm a função crucial de tomar decisões estratégicas, gerenciar recursos e garantir o sucesso da empresa.

Requisito 2 - Liderança e compromisso (cláusula 5)

A alta liderança da organização deve demonstrar propriedade e compromisso com a certificação, participando de programas de treinamento e oferecendo às equipes envolvidas os recursos necessários para realizarem o seu trabalho com eficiência.

Requisito 3 - Planejamento para gerenciamento de riscos (cláusula 6)

A ISO 27001 não determina um rol taxativo de medidas para as companhias implementarem. Em vez disso, a norma exige que as organizações adaptem medidas e políticas de segurança exclusivas e personalizadas para a realidade de seus negócios.

Requisito 4 - Alocação de recursos (cláusula 7)

Aqui, exige-se que as empresas aloquem os recursos necessários para atender aos requisitos para obter e gerenciar esse selo, bem como assumam o compromisso de que as funções, responsabilidades e autoridades estejam claramente definidas.

Requisito 5 - Avaliações dos controles operacionais (cláusula 8)

A ISO 27001 exige que as organizações monitorem continuamente seu SGSI e avaliem se o desempenho dos controles e políticas implementadas é eficaz.

Com avaliações periódicas de desempenho, espera-se que as companhias melhorem seus sistemas para atender aos requisitos de forma consistente.

Além disso, essas avaliações de desempenho devem ser documentadas e apresentadas como evidência durante uma auditoria para demonstrar a sua conformidade.

Requisito 6 - Avaliação de desempenho (cláusula 9)

As instituições devem realizar várias auditorias internas para monitoramento, medição, análise e avaliação do seu SGSI.

Essas auditorias devem garantir que o segurança da informação sistema de gestão atende às metas e objetivos do negócio, bem como aos requisitos de ISO 27001, sendo revisadas no estágio de credenciamento por um auditor externo independente.

Requisito 7 - Plano de melhoria e correção de não conformidades (cláusula 10)

Em linhas gerais, sempre que houver uma não conformidade no seu SGSI, sua organização deve documentar esse contratempo, com razões que explicam o que causou a ocorrência e quais serão as medidas corretivas implementadas.

LGPD x ISO 27000

Lei 13709	ISO 27002
Capitulo 1 – Disposições Gerais	Item 4.1 – Entendendo a organização
Capitulo 2 – Tratamento de dados pessoais	4.2 – Partes interessadas 4.3 – Escopo de atuação 4.4 - Governança
Capitulo 3 – Direitos do Titular	4.4 – Governança 5.2 – Política de Segurança de dados 5.3 - Responsabilidades 6 – Planejamento 8 – Riscos 9 – Melhoria Continua

LGPD x ISO 27000

Lei 13709	ISO 27002
Capitulo 4 – Tratamento de dados pelo poder público	4.2 – Partes interessadas 4.3 – Escopo de atuação 4.4 - Governança 4.4 – Governança 5.2 – Politica de Segurança de dados 5.3 - Responsabilidades 6 – Planejamento 8 – Riscos 9 – Melhoria Continua
Capitulo 5 – Transferência Internacional de dados	Idem ao anterior

LGPD x ISO 27000

Lei 13709	ISO 27002
Capitulo 6 – Agentes de tratamento de dados	4.4 - Governança
	5.3 - Responsabilidades
	6 – Planejamento
	8 – Riscos
	9 – Melhoria Continua
Capitulo 7 – Segurança de dados	ISO 27001
Capitulo 8 – ANPD	4.4 - Governança
	5.3 - Responsabilidades
	6 – Planejamento
	8 – Riscos
	9 – Melhoria Continua



Quem são os atores ?



O TITULAR:

Pessoa natural que tem seus dados pessoais tratados pelo controlador;



O CONTROLADOR: *

Pessoa natural ou jurídica, de direito público ou privado, a quem competem **as decisões referentes ao tratamento de dados pessoais**;



O OPERADOR: *

Pessoa natural ou jurídica, , de direito público ou privado, **que realiza o tratamento de dados pessoais em nome do controlador**;



O ENCARREGADO - DPO (Data Protection Officer):

Pessoa indicada pelo controlador para atuar **como canal de comunicação** entre o controlador, os titulares dos dados e a **Autoridade Nacional de Proteção de Dados**;

Competência dos Profissionais envolvidos

- ☐ Segurança da Informação
- ☐ Gestão da Informação
 - Administração de Dados / Banco de Dados
 - Gestão de Processos
 - Gestão de Sistemas
 - Gestão da Qualidade
- ☐ Compliance
- ☐ Marketing
- ☐ Análise de Riscos
- ☐ Direito –conhecimento das leis e políticas públicas
 - Gestão de mudanças / cultura organizacional
 - Comunicação, inclusive com a alta gerência
 - Poder de persuasão / psicologia

Algumas atividades para estar em “Compliance”

- ☐ Mapeamento dos canais de entrada de dados pessoais
- ☐ Identificar os focos de tratamento de dados pessoais (marketing, RH, vendas, empresas terceirizadas)
- ☐ Identificar foco de documentos pessoais físicos e digitais;
- ☐ Definir regras de privacidade / modelo de governança;
- ☐ Conscientizar funcionários / campanhas internas / gestão da mudança;
- ☐ Revisar Sistemas de Informação;
- ☐ Revisar rotinas de tratamento de dados;
- ☐ Revisar contratos e relações com terceiros;
- ☐ Proteger os dados: Anonimização, Pseudomização e Criptografia;
- ☐ Elaborar planos de resposta a incidentes e remediação;
- ☐ Estar pronto para a auditoria: Gerenciamento, rastreamento e relatórios.

Autoridade Nacional de Proteção de Dados - ANPD

← → ↻ 📄 www.gov.br/anpd/pt-br

gov.br

Ministério da
Justiça e...

Órgãos do Governo

Acesso à Informação

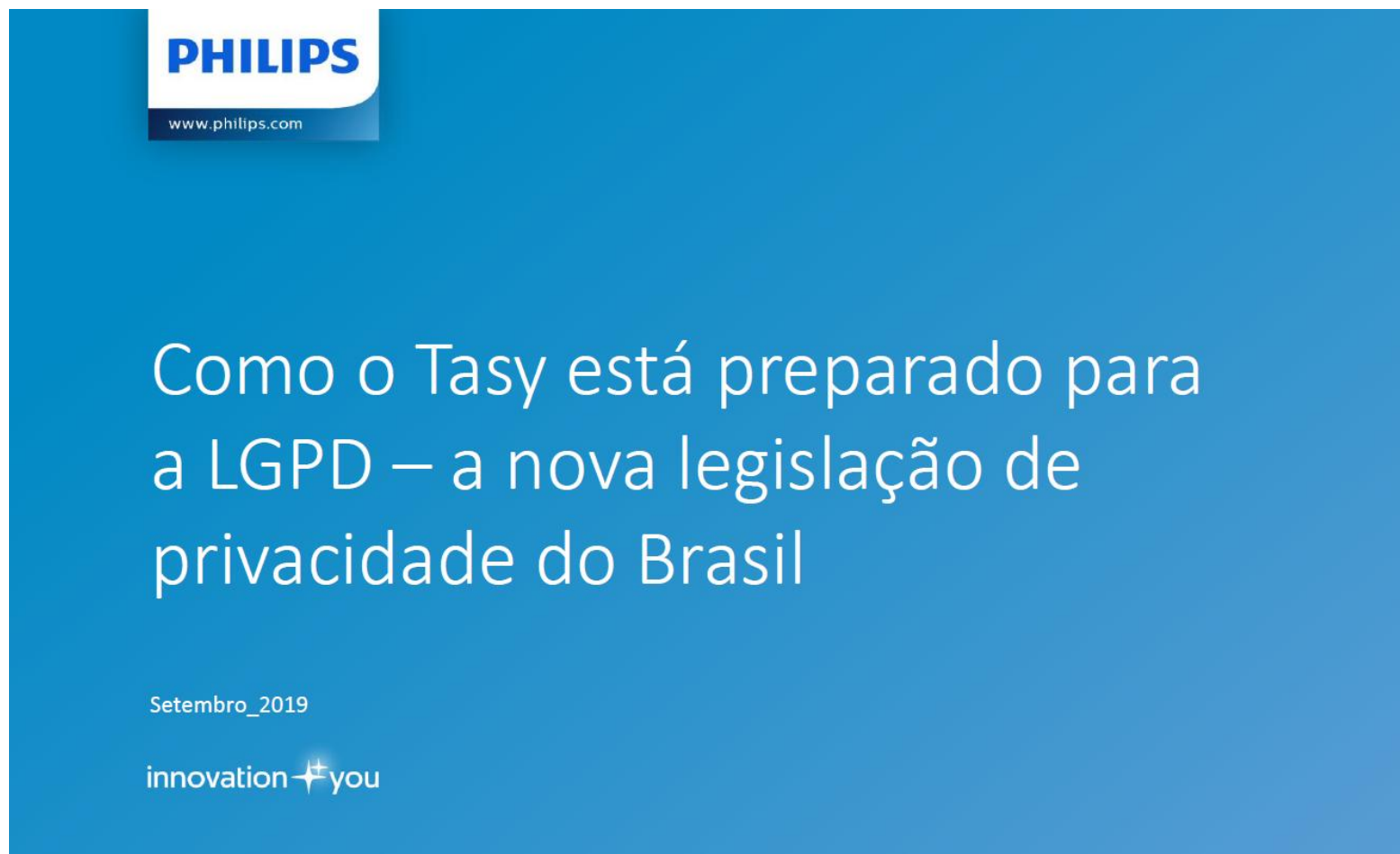
Legislação

≡ Autoridade Nacional de Proteção de Dados

Competências ANPD

- ☐ Editar regulamentos e procedimentos e medidas cabíveis sobre proteção de dados pessoais e privacidade;
- ☐ Promover o conhecimento das normas e políticas públicas sobre proteção de dados pessoais e das medidas de segurança;
- ☐ Realizar auditorias e celebrar compromissos para eliminação de irregularidades;
- ☐ Deliberar sobre a interpretação desta Lei, suas competências e os casos omissos;
- ☐ Fiscalizar e aplicar sanções nos casos de descumprimento da legislação;
- ☐ Dispor sobre padrões e técnicas utilizados em processos de anonimização e realizar verificações acerca de sua segurança, ouvido o Conselho Nacional de Proteção de Dados Pessoais.

O que o mercado fala ? Case TASY



Fonte: <https://www.philips.com/c-dam/b2bhc/br/consulting/E-book-Privacidade-de-dados-Tasy-EMRpdf.pdf>

Referências

<https://www.linkana.com/blog/o-que-e-background-check>

<https://www.unimed.coop.br/site/web/blumenau/politica-de-privacidade>

<https://registrodemarca.arenamarcas.com.br/o-que-e-a-lgpd/>

<https://www.acpdbrasil.com/normas-tecnicas-para-a-lgpd/>

<https://www.infranewstelecom.com.br/controlador-operador-encarregado-quem-e-quem-na-lgpd/>

<https://www.clicksign.com/blog/o-que-e-iso-27001>

<https://www.gov.br/anpd/pt-br>

UnISENAI

Rua do São Paulo, Victor Konder, Blumenau

 3210 4567

unisenaisc.com.br



SENAI